

Phishing Detection & Awareness Report

Task 2 — Email Sample Analysis, Indicator Identification, Risk Classification & Prevention Guidelines

Dataset Source	CEAS 2008 Spam / Phishing Challenge Corpus (gvc.ceas-challenge.cc)
Samples Analyzed	5 email samples
Analysis Type	Header inspection, sender/domain verification, content & link analysis, social-engineering pattern
Prepared For	Task 2 Deliverable — Phishing Detection & Awareness Report

1. Executive Summary

This report documents the analysis of five email samples drawn from the CEAS 2008 spam/phishing challenge dataset. Each email was examined for sender authenticity, domain alignment, embedded links, content structure, and social-engineering technique. Four of the five samples were classified as malicious (spam, scam, or phishing) and one was classified as legitimate (ham), included as a control example to demonstrate the contrast between benign automated notifications and malicious mail. The report concludes with a consolidated set of indicators of compromise (IOCs), a risk classification table, and prevention guidelines suitable for end-user awareness training.

2. Analysis Approach

Each email sample was evaluated across four dimensions:

- **Sender/Header Analysis** — checking whether the display name matches the actual sending domain, and whether the domain is plausible for the claimed sender.
- **Link/URL Analysis** — identifying mismatched, shortened, or third-party hosting links used to redirect victims.
- **Content Analysis** — reviewing subject/body text for urgency, unrealistic offers, obfuscated text used to evade spam filters, and brand impersonation.
- **Behavioral/Social-Engineering Pattern** — classifying the persuasion technique used (e.g., discount lure, brand trust exploitation, filter-evasion noise).

Risk was then classified as **Low**, **Medium**, **Medium-High**, or **High** based on the combination of technical deception (domain spoofing, redirect links) and potential harm (credential theft, malware delivery, financial fraud).

3. Analyzed Email Samples

Sample 1 — Phishing / Malicious-Redirect Spam

From Gretchen Suggs <externalsep1@loanofficertool.com>
To user2.2@gvc.ceas-challenge.cc
Date Tue, 05 Aug 2008 19:31:21 -0400

SpecialPrices Pharm Moreinfo Welcome FastShipping CustomerSupport
<http://7iwfna.blu.livefilestore.com/y1pXdX3kwzhBa8xhXv8tdHbjHn7T...>

Identified Indicators:

- Sender domain (loanofficertool.com) has no relation to the pharmaceutical content being advertised — classic domain/content mismatch.
- Embedded link points to a free cloud file-hosting subdomain (blu.livefilestore.com) rather than a legitimate pharmacy domain — a common redirect/malware-hosting tactic.

- Keyword-stuffed subject/body ("SpecialPrices", "FastShipping", "CustomerSupport") typical of unsolicited pharmaceutical spam campaigns.
- No personalization; generic recipient handling consistent with bulk spam distribution.

Risk Classification: **High**

Sample 2 — Spam with Filter-Evasion Obfuscation (Potential Phishing Vector)

From Caroline Aragon <dwthaidomainnamesm@thaidomainnames.com>
To user7-ext5@gvc.ceas-challenge.cc
Date Wed, 06 Aug 2008 05:31:22 +0600

Raw content excerpt:

Yo wu urS mo ou go rc ebo eForM rgi oreWo iyv m ww en C mo L cfd IC eym K HE uys RE!!!

Identified Indicators:

- Body text is deliberately fragmented with random character insertion — a filter-evasion technique designed to defeat keyword-based and Bayesian spam filters (e.g., hiding "CLICK HERE" inside noise).
- Sender domain (thaidomainnames.com) is unrelated to the display name "Caroline Aragon", suggesting a spoofed/throwaway identity.
- No coherent legitimate business purpose is discernible from the content.
- Because the underlying call-to-action ("CLICK HERE") is obfuscated rather than removed, any linked destination should be treated as high-risk and unverified.

Risk Classification: **Medium-High**

Sample 3 — Counterfeit-Goods Scam Spam

From Replica Watches <jhorton@thebakercompanies.com>
To user2.10@gvc.ceas-challenge.cc
Date Tue, 05 Aug 2008 21:44:01 +0000

Raw content excerpt:

Replica Watches
We have fake Swiss Men's and Ladie's Replica Watches from Rolex to the Popular Panerai Watch More
i...

Identified Indicators:

- Display name "Replica Watches" does not match the sending domain (thebakercompanies.com), indicating a hijacked or spoofed mailbox used for unrelated commercial spam.
- Content explicitly advertises counterfeit goods ("fake Swiss... Replica Watches"), a known category of scam/fraud spam.

- Truncated body ("More i...") suggests a tracking or redirect link was likely stripped/truncated in the sample capture.
- No legitimate retailer would openly market counterfeit branded goods — strong scam indicator.

Risk Classification: Medium

Sample 4 — Brand Impersonation Phishing

From Daily Top 10 <acidirev_1972@tcwpg.com>
To user2.3@gvc.ceas-challenge.cc
Date Tue, 05 Aug 2008 20:41:14 -0300

News content analysis

[illegible]

Identified Indicators:

- Email impersonates a trusted media brand (CNN.com) while actually originating from an unrelated domain (tcwpg.com) — a textbook brand-impersonation phishing pattern.
- Sender local-part ("acidirev_1972") looks like an auto-generated/throwaway account, inconsistent with an official CNN mailing system.
- Decorative ASCII banner formatting ("+=+=+=...") is a hallmark of early-2000s mass-mailed spam/phishing newsletters designed to look like legitimate digests.
- Because it borrows a trusted brand identity, recipients are more likely to click embedded links without scrutiny.

Risk Classification: High

Sample 5 — Legitimate Automated Notification (Ham) — Control Example

From qydlqcws-iacfym@issues.apache.org
To xrh@spamassassin.apache.org
Date Tue, 05 Aug 2008 15:31:03 -0800

News content events

```
[Bug 5780] URI processing turns uuencoded strings into http URI's which then causes FPS
http://issues.apache.org/SpamAssassin/show_bug.cgi?id=5780
wrzzpv@sidney.com changed: ...
```

Identified Indicators:

- Sender and recipient domains both resolve to the legitimate Apache Software Foundation infrastructure (apache.org) — domain alignment confirmed.

- The embedded link points to the same apache.org domain referenced in the message body (issues.apache.org), with no redirect or third-party hosting.
- Content is a routine, technically coherent automated bug-tracker notification consistent with Apache Bugzilla's known format.
- No urgency language, no financial/personal-data request, no brand impersonation — none of the standard phishing indicators are present.

Risk Classification: Low

3.1 Header Verification Tool — Google Admin Toolbox (Messageheader)

In addition to manual sender/domain and link review, raw email headers for the samples were cross-checked using **Google Admin Toolbox — Messageheader** (<https://toolbox.googleapps.com/apps/main/>). This tool parses the raw RFC 822 header of an email and reports:

- **SPF (Sender Policy Framework) result** — whether the sending server was authorized to send mail for the claimed domain.
- **DKIM (DomainKeys Identified Mail) result** — whether the message was cryptographically signed by the sending domain and not tampered with in transit.
- **Full delivery path** — every mail server hop the message passed through, the delay between hops, the protocol used (SMTP/ESMTPS), and the timestamp at each stage.

An unexplained relay through an unrelated third-party server, an unusually long delay at one hop, or a failed SPF/DKIM result are additional technical indicators that reinforce the manual sender/domain findings in Section 3. The format of the tool's output is illustrated below (illustrative format — actual per-sample screenshots were captured during analysis and can be attached separately as evidence):

Subject:		Meetups this week with: Board gamers, Finance and others				
SPF:		pass				
DKIM:		pass				

#	Delay	From		To	Protocol	Time Received
0		mail7.nyi.meetup.com	→	COL004-MC1F51.hotmail.com		4/11/2016, 11:31:44 AM
1	2 sec	COL004-MC1F51.hotmail.com	→	COL004-OMC4S14.hotmail.com		4/11/2016, 11:31:46 AM
2	3 mins	col004-omc4s14.hotmail.com	→	[Google] mx.google.com	ESMTPS	4/11/2016, 11:34:20 AM
3			→	[Google] 10.98.70.138	SMTP	4/11/2016, 11:34:20 AM
4			→	[Google] 10.103.12.130	SMTP	4/11/2016, 11:34:20 AM

Figure: Illustrative format of Google Admin Toolbox Messageheader output — showing SPF/DKIM authentication results and hop-by-hop delivery path with per-hop delay, protocol, and timestamp. This same view was used to inspect the raw headers of the five analyzed samples for authentication failures and unexplained relay hops.

4. Risk Classification Summary

#	Sender	Type	Key Indicator	Risk Level
---	--------	------	---------------	------------

1	Gretchen Suggs (loanofficertool.com)	Phishing / Malicious redirect	Domain mismatch + free-host redirect link	High
2	Caroline Aragon (thaidomainnames.com)	Spam w/ filter evasion	Obfuscated "CLICK HERE" text	Medium-High
3	Replica Watches (theba kercompanies.com)	Counterfeit-goods scam	Display name/domain mismatch, illegal goods	Medium
4	Daily Top 10 (tcwpg.com)	Brand impersonation phishing	Impersonates CNN.com from unrelated domain	High
5	Apache Bugzilla (issues.apache.org)	Legitimate (Ham)	Domain-aligned, no red flags	Low

5. Consolidated Phishing Indicators Observed

- **Sender/domain mismatch** — display name or advertised brand does not match the actual sending domain (Samples 1, 3, 4).
- **Brand impersonation** — trusted brand names (e.g., CNN.com) used to lower recipient suspicion (Sample 4).
- **Suspicious or third-party redirect links** — links hosted on generic free file-storage or unrelated domains rather than the sender's own domain (Sample 1).
- **Text obfuscation / filter evasion** — deliberately broken or noise-padded text used to slip past automated spam filters while still carrying a call-to-action (Sample 2).
- **Unrealistic or illicit offers** — heavily discounted pharmaceuticals or counterfeit branded goods, a hallmark of scam campaigns (Samples 1, 3).
- **Generic bulk-mail formatting** — decorative ASCII banners, lack of personalization, generic recipient addressing (Samples 1, 2, 4).
- **Domain alignment as a positive (benign) signal** — when sender, recipient, and embedded links all belong to the same legitimate domain with no urgency or financial ask, the message is far more likely to be genuine (Sample 5).

6. Prevention Guidelines

6.1 For End Users

- Always check the actual sending email address, not just the display name — hover over or tap-and-hold to reveal it before trusting a message.
- Never click links in unsolicited emails; instead, navigate to the organization's website directly by typing the URL or using a saved bookmark.
- Be suspicious of urgency, unrealistic discounts, or offers that seem "too good to be true" (e.g., steep pharmacy discounts, counterfeit luxury goods).

- Watch for text that looks broken, garbled, or padded with random characters — this is often an attempt to bypass spam filters and should raise suspicion, not lower it.
- Verify brand-related emails (newsletters, alerts) by checking the sender's domain against the brand's official domain.
- Do not download attachments or enter credentials/payment details from emails you did not expect.
- Report suspicious emails to your organization's IT/security team or use built-in "Report Phishing" features in your email client.

6.2 For Organizations / IT Teams

- Enforce email authentication protocols — SPF, DKIM, and DMARC — to reject or flag messages from spoofed domains.
- Deploy layered spam/phishing filtering (content-based, reputation-based, and link-sandboxing) rather than relying on a single detection method.
- Maintain domain and URL reputation block-lists, and inspect links for redirect chains through free hosting or URL-shortening services.
- Run regular phishing-simulation and security-awareness training so employees can recognize brand impersonation and lure tactics.
- Log and review filter-evasion patterns (obfuscated text, unusual character spacing) as they often indicate an evolving spam campaign.
- Establish a clear, easy internal process for reporting and triaging suspected phishing emails.

7. Conclusion

Of the five samples analyzed, four exhibited clear indicators of malicious intent — domain spoofing, brand impersonation, suspicious redirect links, or filter-evasion obfuscation — and were classified from Medium to High risk. The fifth sample, a legitimate Apache Bugzilla notification, served as a useful control case, confirming that domain alignment and the absence of urgency or financial requests are strong positive indicators of a genuine email. Consistent application of the indicators and prevention guidelines in this report can meaningfully reduce the likelihood of successful phishing attacks against both individual users and organizations.